

NMAP su CyberOps Workstation

Nmap (Network Mapper) è un software open source utilizzato per l'esplorazione di rete e l'audit della sicurezza. È considerato lo standard di settore per scoprire quali dispositivi sono connessi a una rete e quali servizi stanno eseguendo.

Nmap viene utilizzato principalmente per mappare una rete e valutarne la superficie di attacco. Il software interroga la rete per scoprire quali dispositivi sono attivi ed esegue una scansione delle porte per individuare i servizi in ascolto.

È in grado di dedurre con precisione le versioni dei software in esecuzione e il sistema operativo utilizzato dall'host.

Infine, grazie al suo potente motore di scripting, permette di automatizzare compiti complessi come il rilevamento di vulnerabilità specifiche o l'identificazione di configurazioni errate, rendendolo uno strumento indispensabile sia per gli amministratori di sistema che per i penetration tester.

Cercando '/example' nel man di Nmap, scorrendo fino alla seconda istanza, troviamo il comando:

```
nmap -A -T4 scanme.nmap.org
```

Il man può essere il migliore amico o il peggior nemico di un professionista informatico: è ricco di informazioni, ma è facile perdersi nel suo rumore. Cerchiamo con '/-A' e successivamente con '/-T4' per capire bene cosa faccia il comando riportato sopra.

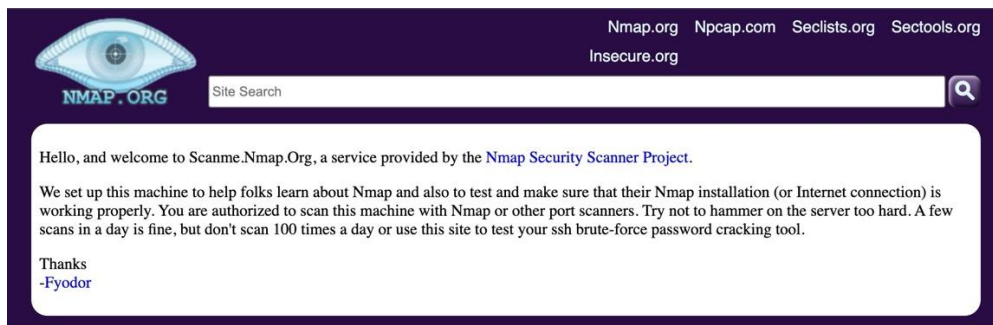
Il parametro -A attiva:

- Il rilevamento del sistema operativo
- Il rilevamento delle versioni
- Controllo di script
- Individua traceroute

Il parametro -T4 impedisce allo scanner di eccedere i 10ms per porta TCP. È raccomandato il suo uso per la scansione di sistemi moderni. Opera fondamentalmente come acceleratore dell'esecuzione.

Lanciando un Nmap verso il nostro localhost vediamo che di porte aperte ce n'è una sola, la 21 (ftp). La versione del servizio è la vsFTPd 3.0.5. Il login anonymous è abilitato.

Scanme.Nmap.Org



Si tratta di una web application di prova su cui si può imparare ad usare Nmap lanciando scansioni autorizzate. È inoltre utile per testare il corretto funzionamento di Nmap installato sul proprio computer o per verificare la connessione internet. I proprietari del sito raccomandano un utilizzo del sito ragionevole, evitando scansioni pesanti e veloci. Si raccomandano anche di non usare tool di brute-forcing contro la porta Ssh.

```
Applications: Terminal - analyst@secO... Terminal - analyst@secOps--
File Edit View Terminal Tabs Help
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-15 10:31 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|_ 2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|_ 256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_ 256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-favicon: Nmap Project
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-title: Go ahead and ScanMe!
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.48 seconds
[analyst@secOps ~]$
```

Lanciando un Nmap verso scanme.nmap.org scopriamo:

- Porta 80 (http) APERTA
 - Server Apache 2.4.7 (Ubuntu)
- Porta 22 (ssh) APERTA
 - OpenSsh 6.6.1p1 (Ubuntu)
- Porte 9929 (nping-echo) & 31337 (tcpwrapped) APERTE
- Sistema operativo: Linux
- Indirizzo IP del server: 45.33.32.156

Conclusioni

Blue team

Per un amministratore o un esperto di cybersecurity, Nmap è fondamentale per la riduzione della superficie di attacco. Viene utilizzato per verificare che solo i servizi necessari siano esposti all'esterno, identificando porte lasciate aperte per errore che potrebbero diventare punti di ingresso.

Attraverso l'uso degli script NSE (Nmap Scripting Engine), i difensori possono scansionare la propria infrastruttura alla ricerca di vulnerabilità note o configurazioni deboli prima che lo faccia un attaccante.

Red team

Un attaccante utilizza Nmap nelle fasi iniziali di un attacco, note come ricognizione ed enumerazione.

In questo contesto, lo strumento serve a tracciare una mappa dettagliata del bersaglio: l'attore malevolo identifica quali server sono attivi, quali sistemi operativi utilizzano e, soprattutto, quali versioni software sono vulnerabili ad exploit specifici.

Una volta individuata una versione obsoleta di un servizio tramite il *version detection*, l'attaccante ha tutte le informazioni necessarie per scegliere l'exploit più efficace e colpire con precisione.

Nmap può essere configurato per essere estremamente furtivo, utilizzando tecniche come le scansioni "TCP SYN" (che non completano la connessione per evitare di essere loggate dai server) o frammentando i pacchetti per eludere i sistemi IDS/IPS.

Ad esempio:

```
sudo nmap -sF scanme.nmap.org
```

Oppure:

```
sudo nmap -sS scanme.nmap.org
```

Questi tipi di scansioni stealth sono molto utili su sistemi Linux/Unix ma completamente inefficaci su Windows, a causa della loro specifica implementazione dello stack TCP/IP, che tende a rispondere con un pacchetto RST indipendentemente dal fatto che la porta sia aperta o chiusa, rendendo la FIN scan o la SYN scan poco utile contro di loro.